

The 0-Day Engine: Finding 100+ Vulns with LLMs in Chrome and Android

Speaker: Fangang Bu & Huiming Liu

ABOUT US



腾讯安全玄武实验室

TENCENT SECURITY XUANWU LAB

Fangang Bu
@povcfe
Security Researcher

Huiming Liu
@liuhm09
Security Researcher

Question: Will large language models replace security researchers?

AGENDA

- THE MOTIVATION
- FROM N-DAY PATCHES TO VARIANTS
- DECONSTRUCTING THE ZERO-DAYS
- LIVE DEMO

1. THE MOTIVATION

1.1 Logic Vulnerabilities Matter

For Android: No code execution needed. The boundary break is the impact.

1. Privilege Escalation & Permissions

- Permission Bypasses
- Special App Access
- While-In-Use (WIU) Abuse

2. UI, Activity, & Multi-User Security

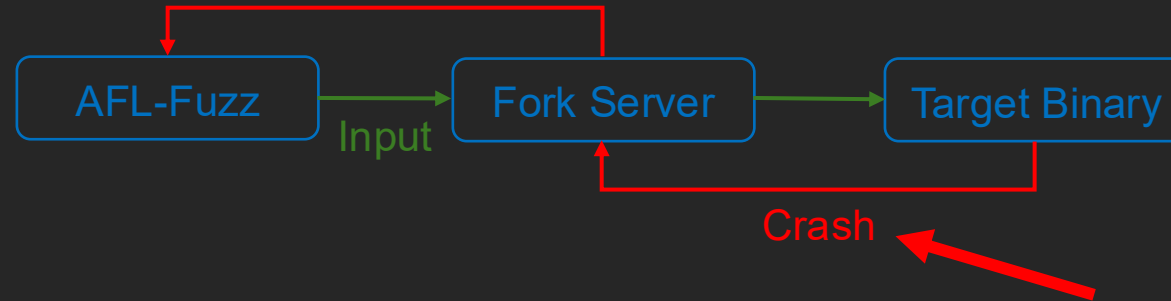
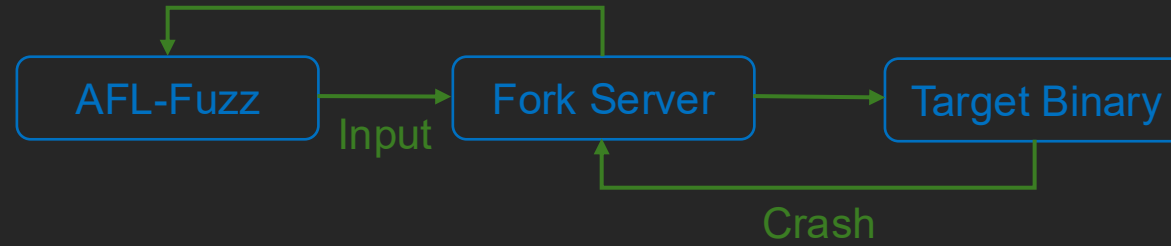
- Activity & Intent Spoofing
- UI Obfuscation & Tapjacking
- Multi-User & Private Space

3. Device Management

- Enterprise Bypasses

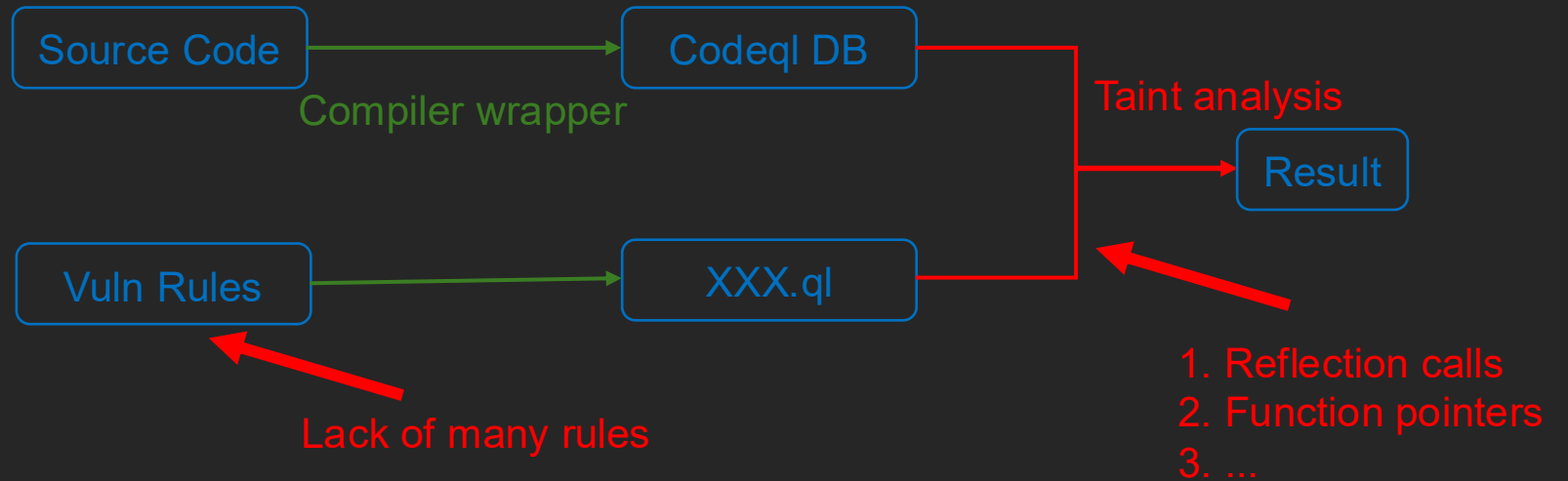
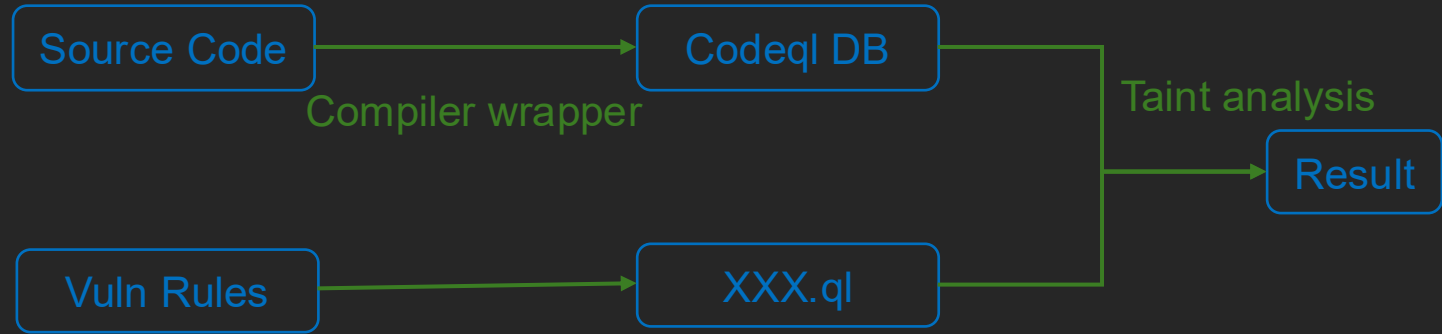
1.2 How Can We Scale Finding Logic Vulnerabilities On Large-scale Codebases?

Fuzz? Such As AFL



1.2 How Can We Scale Finding Logic Vulnerabilities On Large-scale Codebases?

Static Audit? Such As Codeql



1.3 Think Another Way(N-Day)

Too many bugs. Too many models to internalize

1. 3000+ Android security vulnerabilities (2016 – Now)
2. No researcher can internalize every vulnerability model

1.3 Think Another Way(N-Day)

The bug is fixed. The model repeats.

One Repeating Model: Authorization Based on Forged Identity Fields

1. 2020: CVE-2020-0107 / CVE-2020-0246
2. 2021: CVE-2021-0319
3. 2022: CVE-2022-20223 / CVE-2022-20455
4. 2023: CVE-2023-21266 / CVE-2023-40105 / CVE-2023-40127
5. 2024: CVE-2024-0015
6. 2025: CVE-2025-0086 / CVE-2025-48537 / CVE-2025-48585

1.4 How I Did It

Generalization finds candidates. Verification makes them real.

1. Scaling Model N-day Patch Primitives
2. Generalize them into 0-day variants
3. Verify each phase with agents and toolchains

- THE MOTIVATION
- FROM N-DAY PATCHES TO VARIANTS
- DECONSTRUCTING THE ZERO-DAYS
- LIVE DEMO

2. FROM N-DAY PATCHES TO VARIANTS

2.1 The Question

The target question:

1. Does the historical vulnerability still exist?
2. Do similar variants exist elsewhere?

The technical question:

1. How to model N-day patch primitives?
2. How LLM Agents Analyze Large-scale Codebases?
3. How to ensure vulnerabilities are real?
4. How to find vulnerabilities at scale?

2.2 WorkFlow

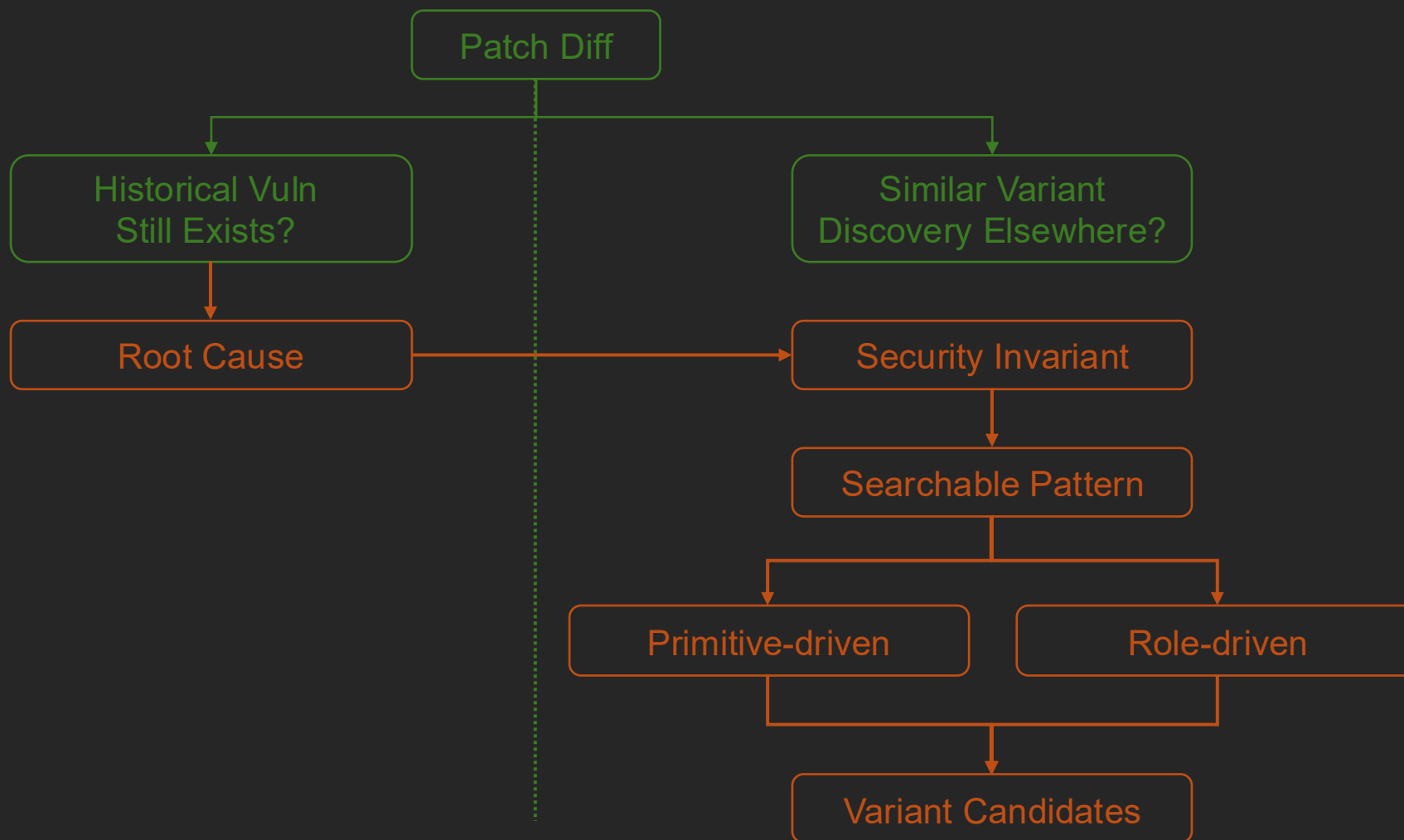
Does the historical vulnerability still exist?

Do similar variants exist elsewhere?



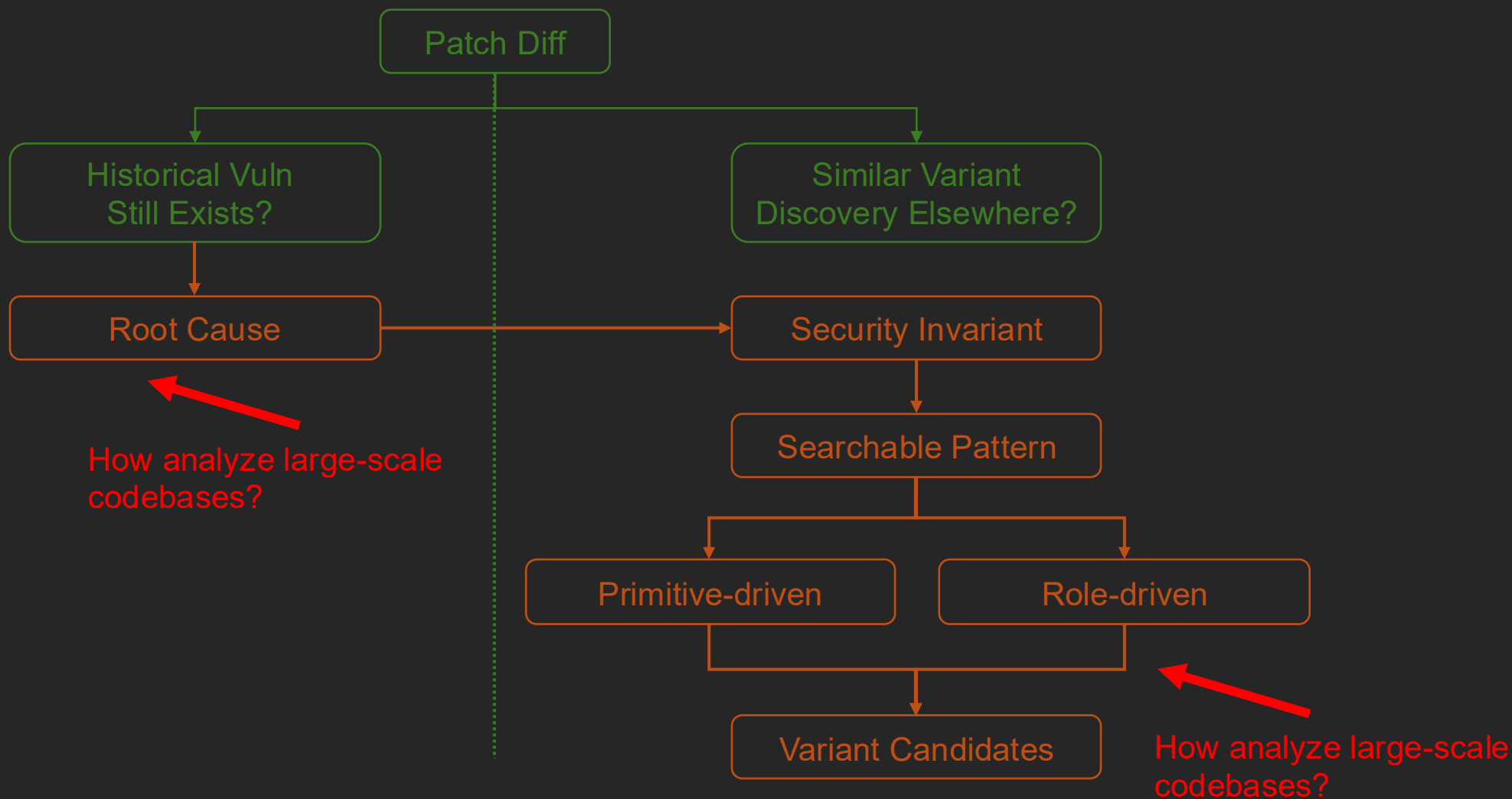
How to model N-day patch primitives?

Thousands of fixes become thousands of searchable vulnerability models.



How to model N-day patch primitives?

Thousands of fixes become thousands of searchable vulnerability models.



How LLM Agents Analyze Large-scale Codebases?

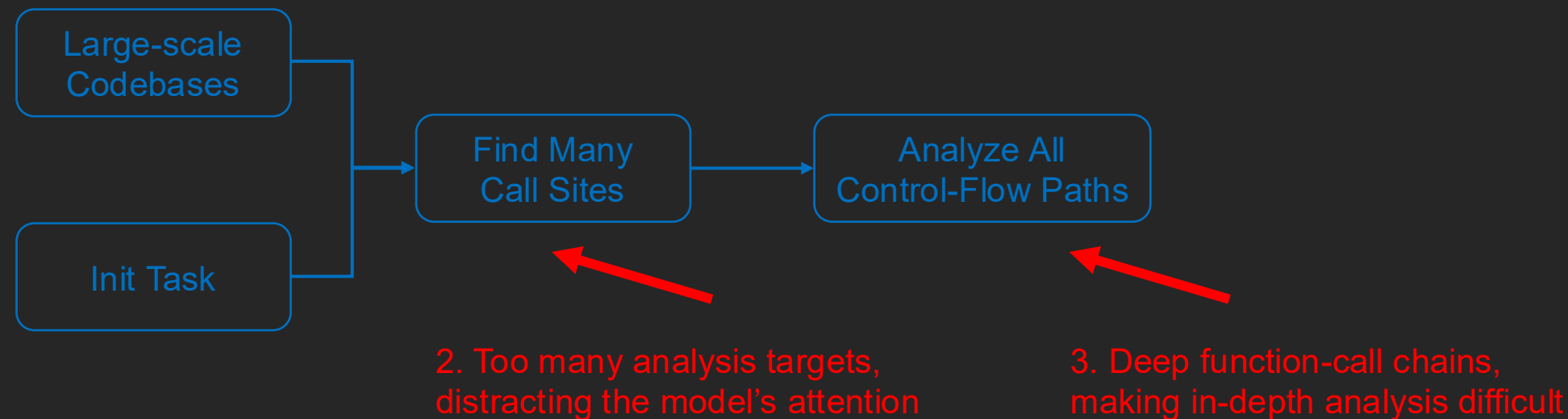
Init Task: Analyze all control-flow paths leading to system() calls.



How LLM Agents Analyze Large-scale Codebases?

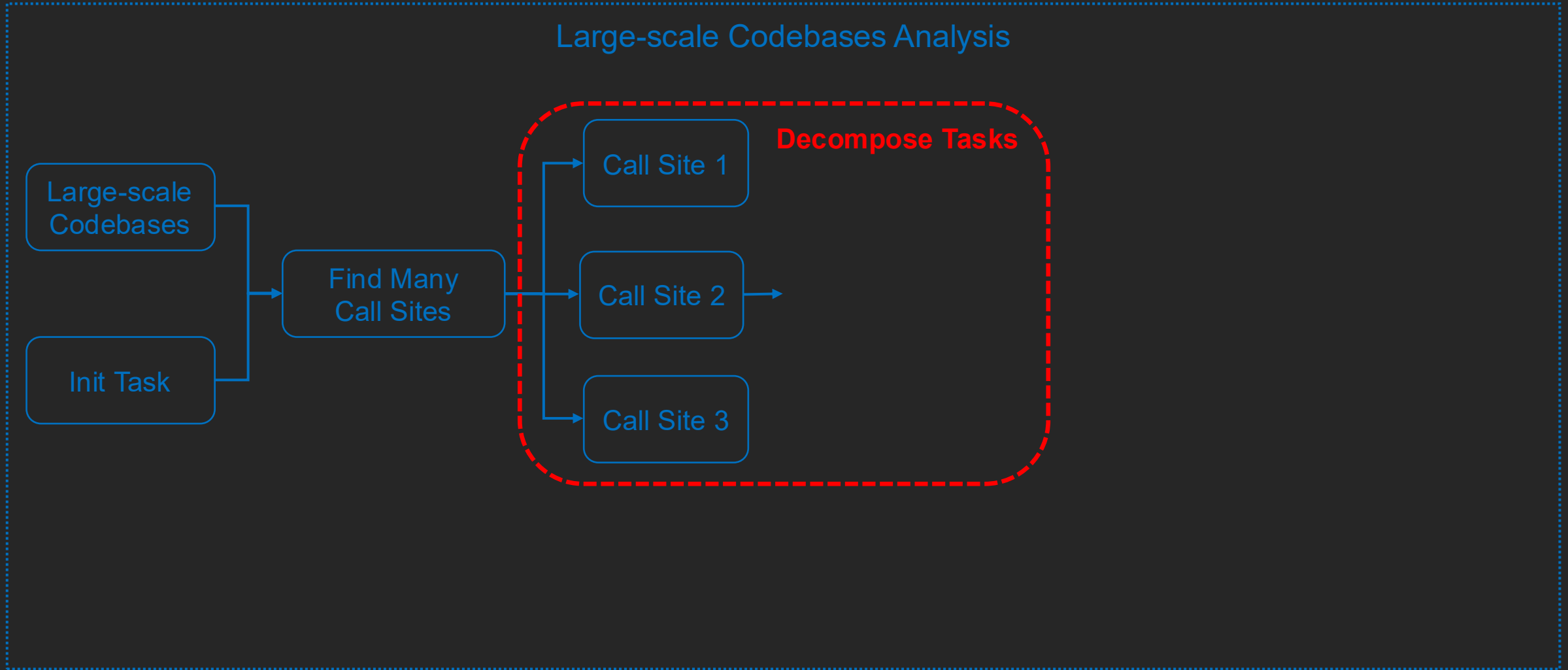
Init Task: Analyze all control-flow paths leading to system() calls.

1. Limited LLM context window



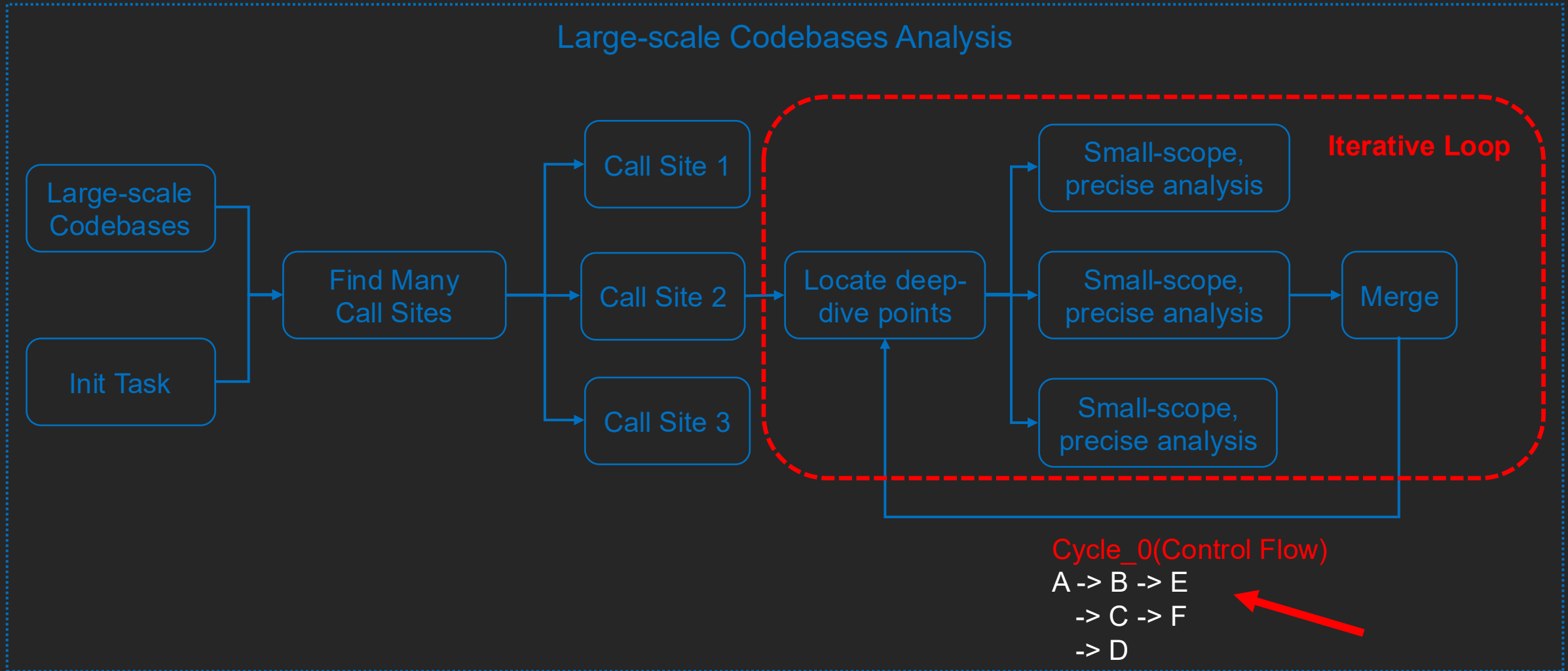
How LLM Agents Analyze Large-scale Codebases: Task Decomposition

One LLM session. One simple task.



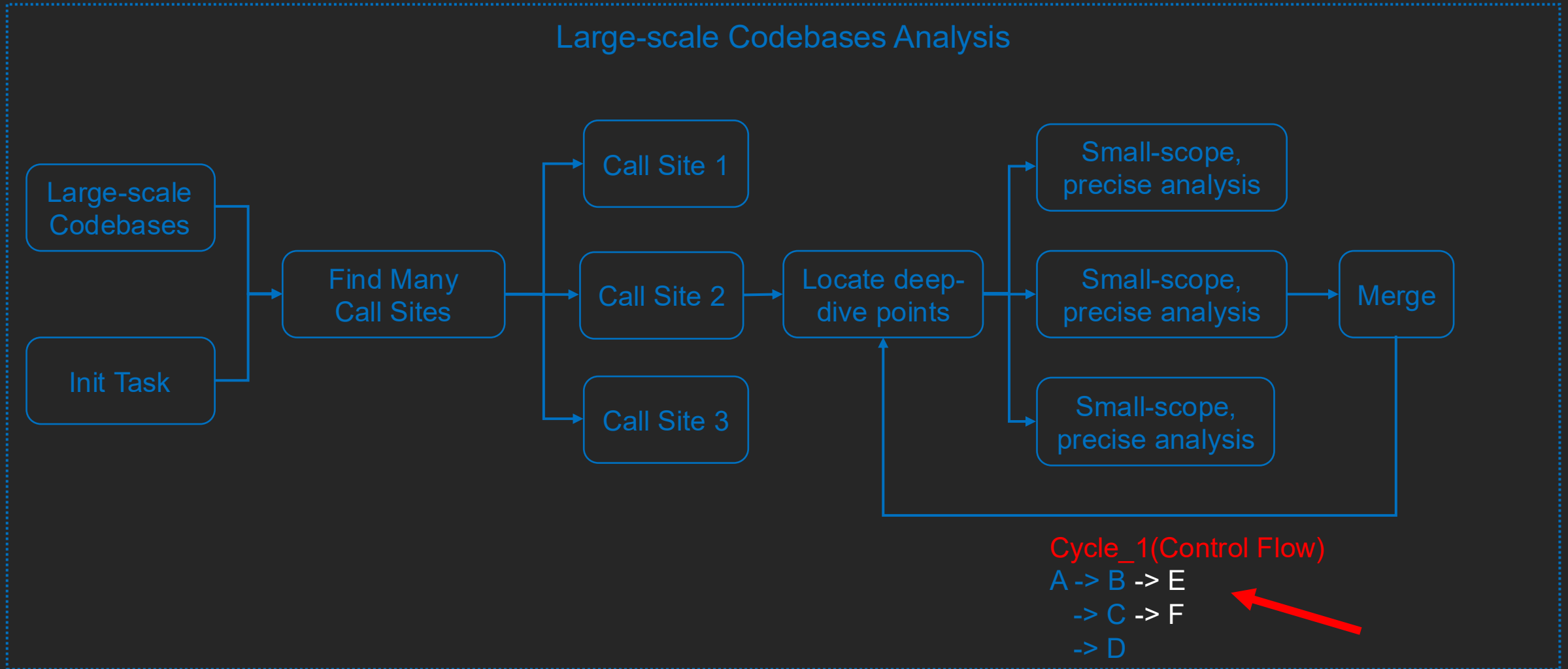
How LLM Agents Analyze Large-scale Codebases: Task Decomposition

One LLM session. One simple task.



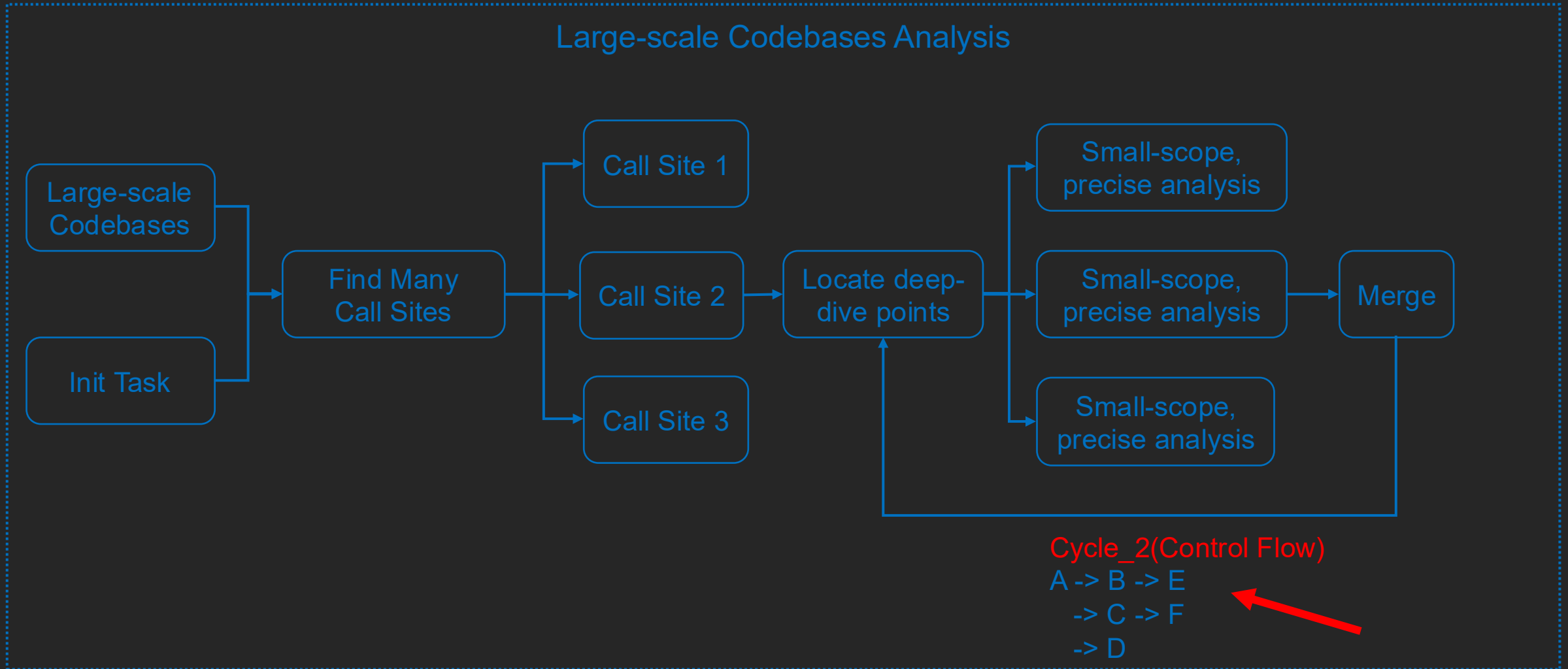
How LLM Agents Analyze Large-scale Codebases: Task Decomposition

One LLM session. One simple task.



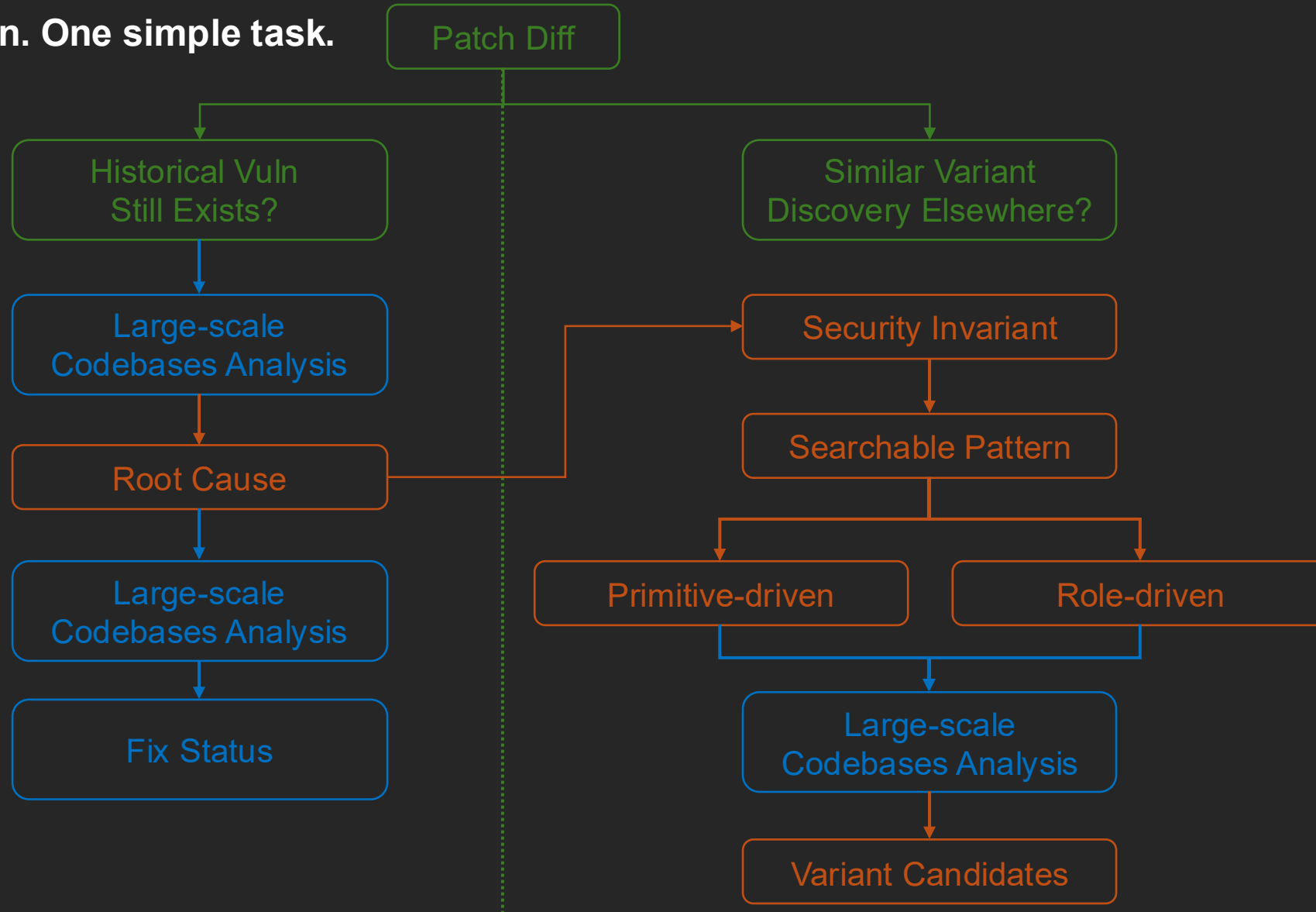
How LLM Agents Analyze Large-scale Codebases: Task Decomposition

One LLM session. One simple task.



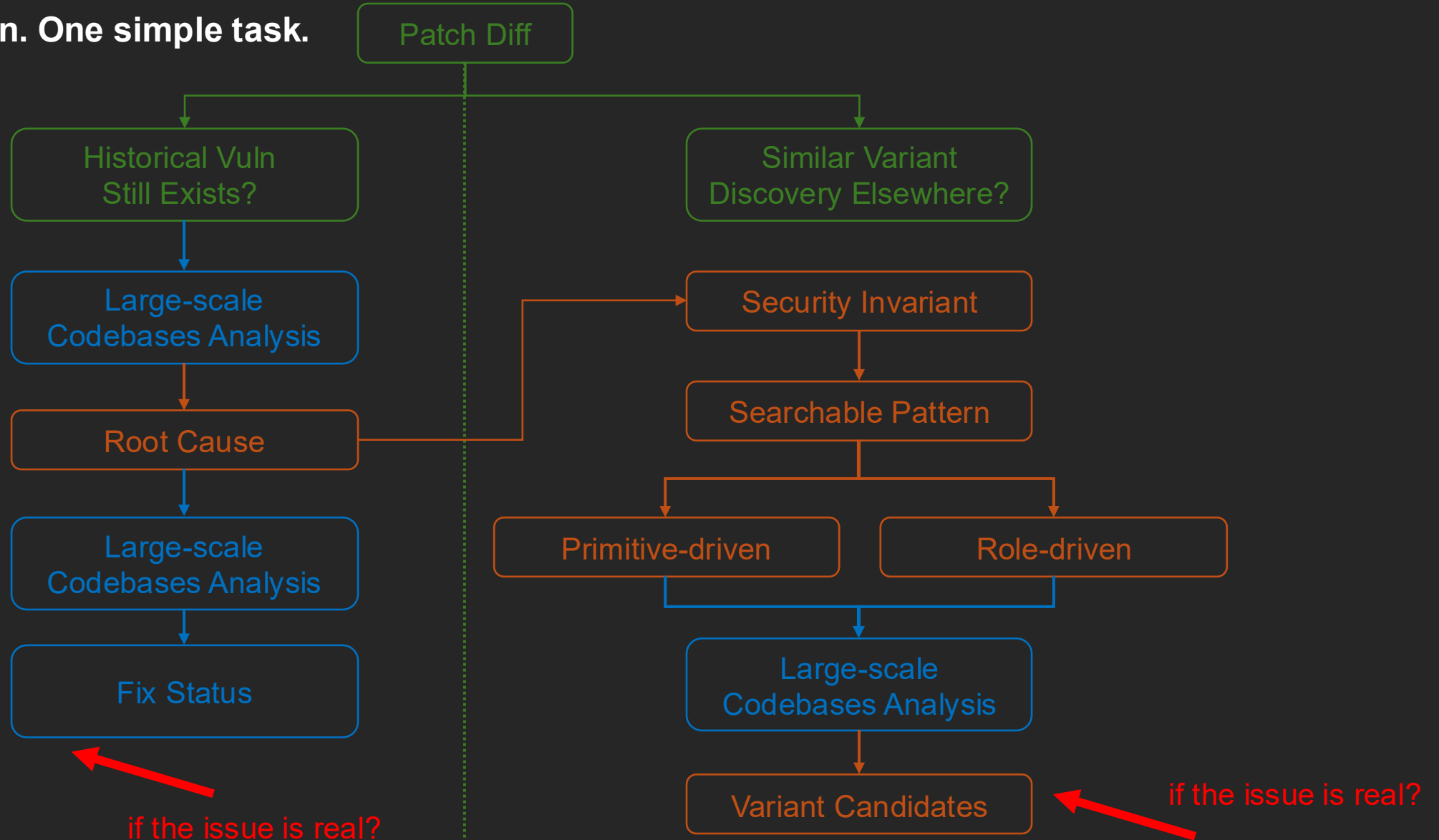
How LLM Agents Analyze Large-scale Codebases: Task Decomposition

One LLM session. One simple task.



How LLM Agents Analyze Large-scale Codebases: Task Decomposition

One LLM session. One simple task.



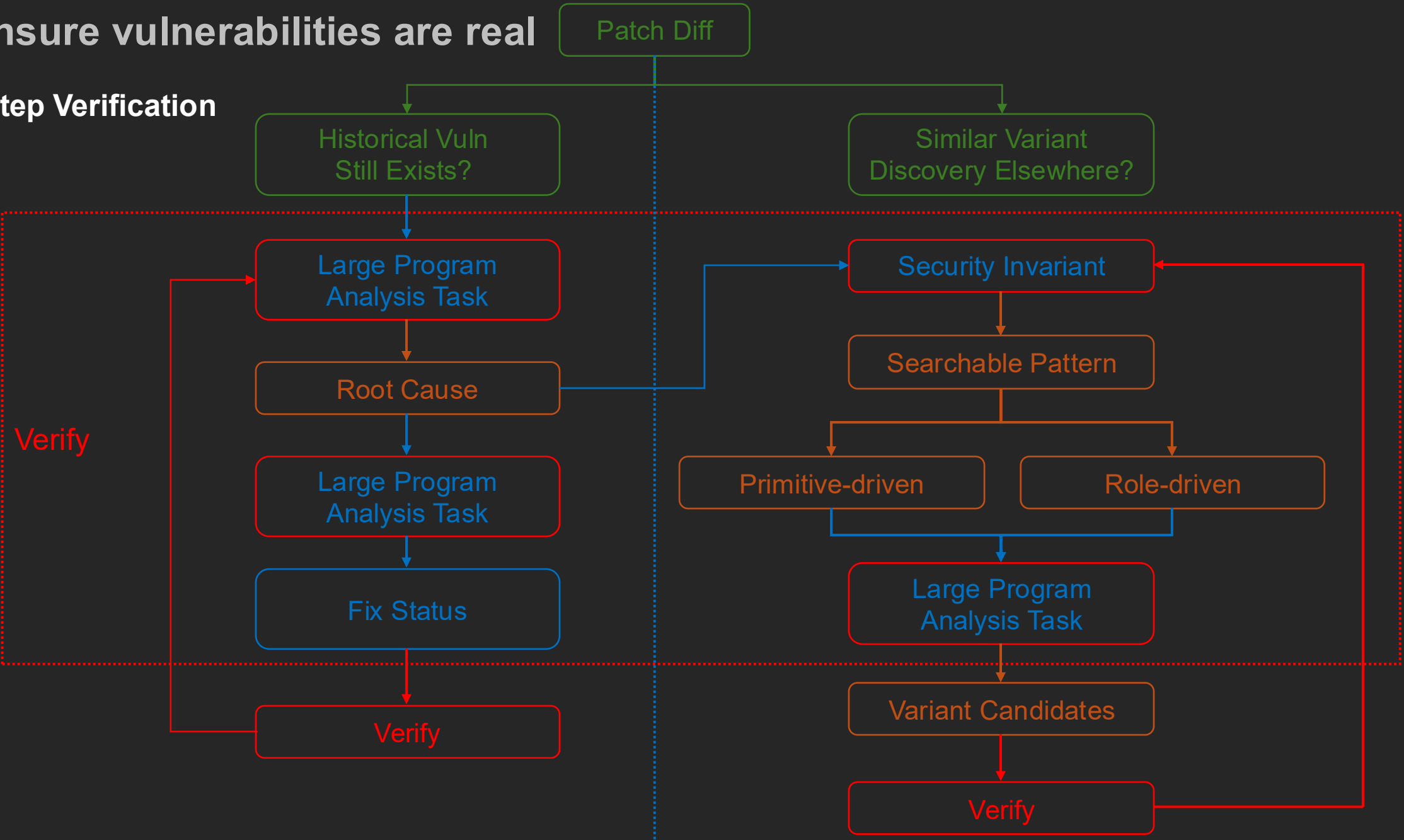
How to ensure vulnerabilities are real

Step-by-Step Verification

1. Build Tools - compile test apps, framework modules, and PoCs.
2. ADB - deploy, trigger, reproduce.
3. Frida & System Monitoring - inspect dynamic behavior and verify runtime state.

How to ensure vulnerabilities are real

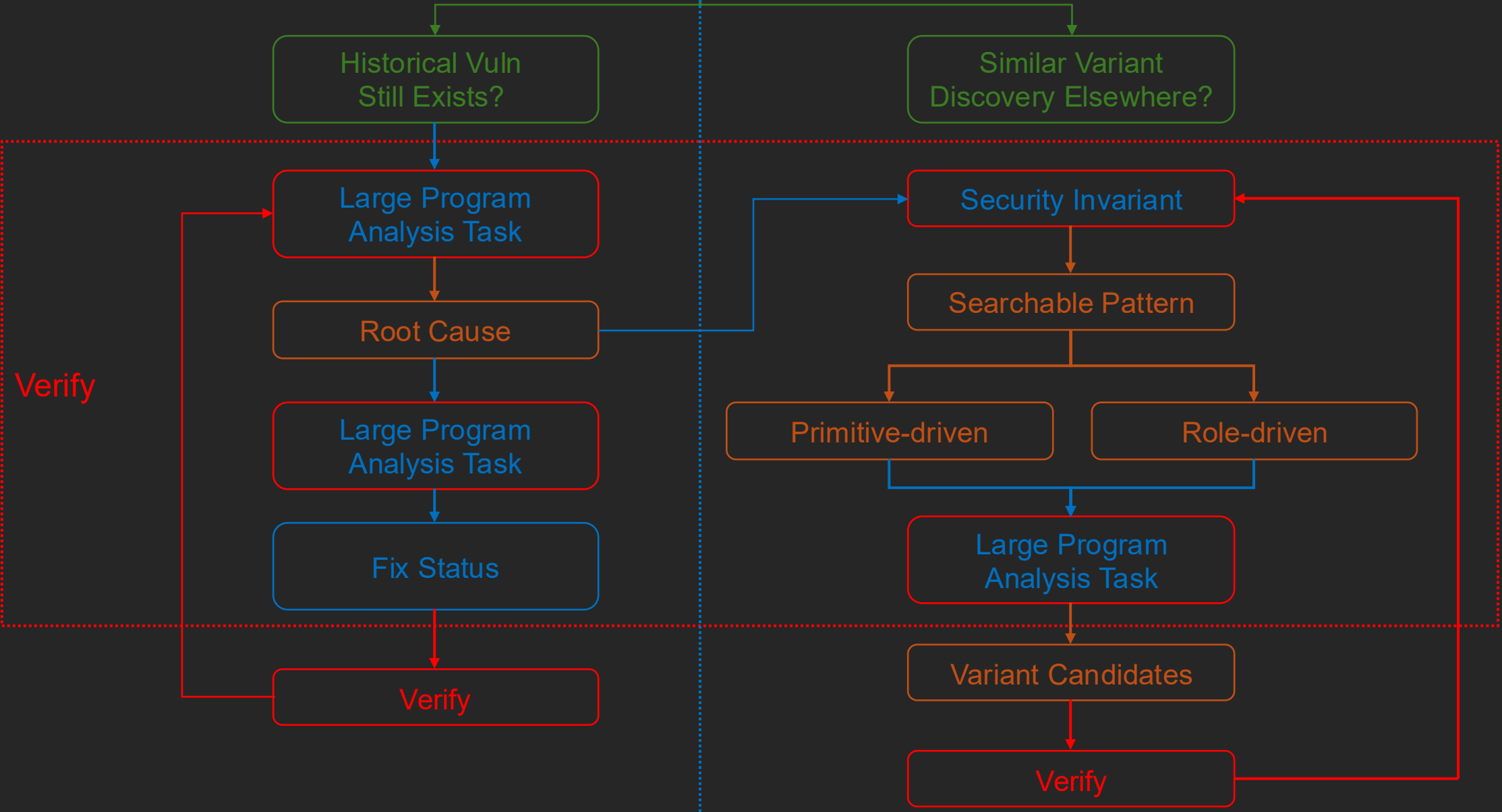
Step-by-Step Verification



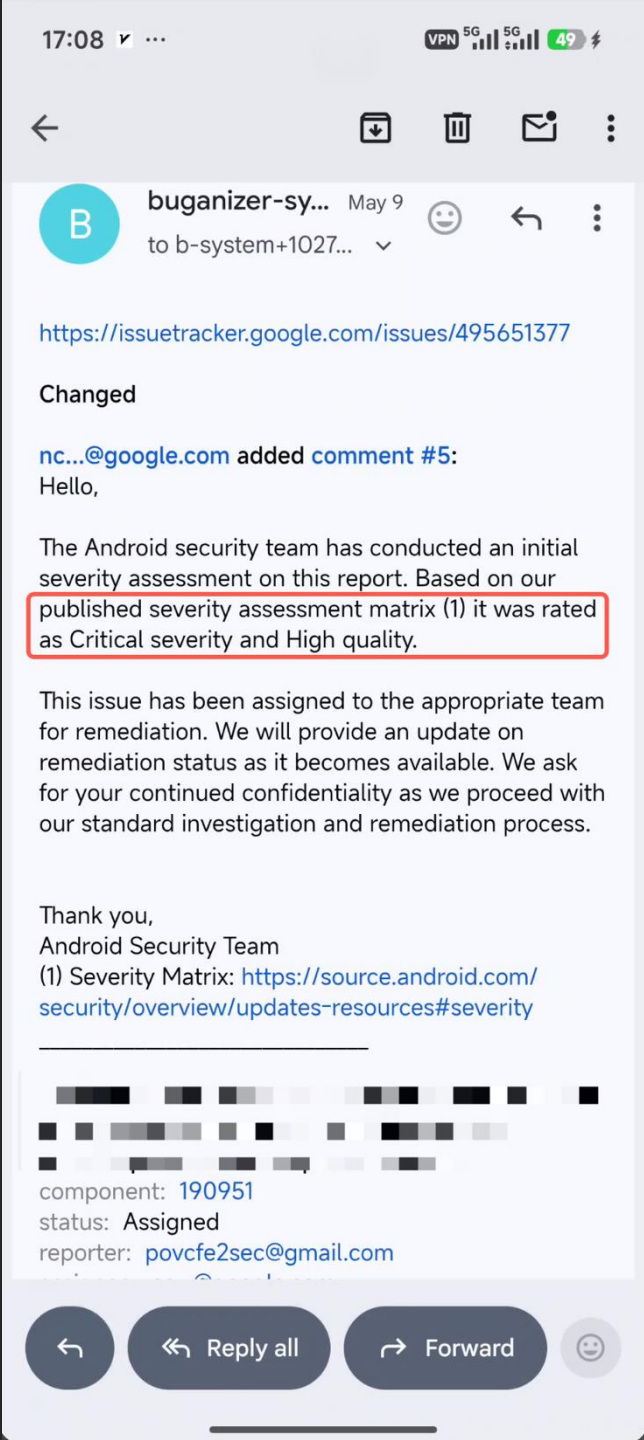
Solve One Problem, Then Scale It

Patch Diff

Android/Chrome/Firefox/Open Source Project



2.6 Result



- THE MOTIVATION
- FROM N-DAY PATCHES TO VARIANTS
- DECONSTRUCTING THE ZERO-DAYS
- LIVE DEMO

3. DECONSTRUCTING THE ZERO-DAYS

3.1 Pin Lock Bypass(CVE)

CVE-2025-48541

```
diff --git a/src/com/android/settings/biometrics/face/FaceSettings.java b/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
index 8270d50a..ce4fdd6 100644
```

```
--- a/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
+++ b/src/com/android/settings/biometrics/face/FaceSettings.java
```


3.1 Pin Lock Bypass(CVE)

CVE-2025-48541

```
diff --git a/src/com/android/settings/biometrics/face/FaceSettings.java b/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
index 8270d50a..ce4fdd6 100644
```

```
--- a/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
+++ b/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
...
```

```
-         mToken = getIntent().getByteArrayExtra(KEY_TOKEN);
```

```
+         if (callingPackage == null || !callingPackage.equals(activity.getPackageName())) {
```

```
+             // only allow these extras when called internally by Settings
```

```
+             mToken = getIntent().getByteArrayExtra(KEY_TOKEN);
```

3.1 Pin Lock Bypass(CVE)

CVE-2025-48541

```
diff --git a/src/com/android/settings/biometrics/face/FaceSettings.java b/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
index 8270d50a..ce4fdd6 100644
```

```
--- a/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
+++ b/src/com/android/settings/biometrics/face/FaceSettings.java
```

```
...
```

```
-         mToken = getIntent().getByteArrayExtra(KEY_TOKEN);
-
-         mSensorId = getIntent().getIntExtra(BiometricEnrollBase.EXTRA_KEY_SENSOR_ID, -1);
-
-         mChallenge = getIntent().getLongExtra(BiometricEnrollBase.EXTRA_KEY_CHALLENGE, 0L);
-
-         mUserId = getActivity().getIntent().getIntExtra(
-             Intent.EXTRA_USER_ID, UserHandle.myUserId());
+         if (callingPackage == null || !callingPackage.equals(activity.getPackageName())) {
+             mUserId = UserHandle.myUserId();
+         } else {
+             // only allow these extras when called internally by Settings
+             mToken = getIntent().getByteArrayExtra(KEY_TOKEN);
+             mSensorId = getIntent().getIntExtra(BiometricEnrollBase.EXTRA_KEY_SENSOR_ID, -1);
+             mChallenge = getIntent().getLongExtra(BiometricEnrollBase.EXTRA_KEY_CHALLENGE, 0L);
```

3.1 Pin Lock Bypass(Zero-Day)

```
diff --git a/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
b/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
--- a/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
+++ b/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
```

3.1 Pin Lock Bypass(Zero-Day)

```
diff --git a/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
b/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
--- a/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
+++ b/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
```

```
+         mAllowInternalExtras = false;
```

```
+         if (TextUtils.equals(callingPackage, activity.getPackageName())) {
```

```
+             mAllowInternalExtras = true;
```

```
-         if (BiometricUtils.containsGatekeeperPasswordHandle(getIntent())) {
```

```
+         if (mAllowInternalExtras && BiometricUtils.containsGatekeeperPasswordHandle(getIntent())) {
```

3.1 Pin Lock Bypass(Zero-Day)

```
diff --git a/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
b/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
--- a/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
+++ b/packages/apps/Settings/src/com/android/settings/biometrics/combination/BiometricsSettingsBase.java
    public void onAttach(Context context) {
-        mUserId = getActivity().getIntent().getIntExtra(Intent.EXTRA_USER_ID,
-            UserHandle.myUserId());
+        mUserId = UserHandle.myUserId();
+        mAllowInternalExtras = false;
+
+        if (context instanceof SettingsActivity) {
+            final SettingsActivity activity = (SettingsActivity) context;
+            final String callingPackage = activity.getInitialCallingPackage();
+            if (TextUtils.equals(callingPackage, activity.getPackageName())) {
+                mAllowInternalExtras = true;
+                mUserId = activity.getIntent().getIntExtra(Intent.EXTRA_USER_ID, mUserId);
+            }
+        }
+
+        if (BiometricUtils.containsGatekeeperPasswordHandle(getIntent())) {
+            if (mAllowInternalExtras && BiometricUtils.containsGatekeeperPasswordHandle(getIntent())) {
```

3.2 UI Obfuscation(CVE)

CVE-2022-20230

```
diff --git a/src/com/android/keychain/KeyChainActivity.java b/src/com/android/keychain/KeyChainActivity.java
```

```
index 67219a5..45be472 100644
```

```
--- a/src/com/android/keychain/KeyChainActivity.java
```

```
+++ b/src/com/android/keychain/KeyChainActivity.java
```

3.2 UI Obfuscation(CVE)

CVE-2022-20230

```
diff --git a/src/com/android/keychain/KeyChainActivity.java b/src/com/android/keychain/KeyChainActivity.java
```

```
index 67219a5..45be472 100644
```

```
--- a/src/com/android/keychain/KeyChainActivity.java
```

```
+++ b/src/com/android/keychain/KeyChainActivity.java
```

```
        String hostMessage = String.format(res.getString(R.string.requesting_server),  
-            uri.getAuthority());  
+            Uri.encode(uri.getAuthority(), "$,;:@&=+"));
```

3.2 UI Obfuscation(CVE)

CVE-2022-20230

```
diff --git a/src/com/android/keychain/KeyChainActivity.java b/src/com/android/keychain/KeyChainActivity.java
```

```
index 67219a5..45be472 100644
```

```
--- a/src/com/android/keychain/KeyChainActivity.java
```

```
+++ b/src/com/android/keychain/KeyChainActivity.java
```

```
@@ -533,7 +533,7 @@
```

```
    Uri uri = getIntent().getParcelableExtra(KeyChain.EXTRA_URI);
```

```
    if (uri != null) {
```

```
        String hostMessage = String.format(res.getString(R.string.requesting_server),
```

```
-            uri.getAuthority());
```

```
+            Uri.encode(uri.getAuthority(), "$,;:@&=+"));
```

```
    if (contextMessage == null) {
```

```
        contextMessage = hostMessage;
```

```
    } else {
```


3.2 UI Obfuscation(Zero-Day)

```
diff --git a/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
b/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
index 00000000..00000000 100644
--- a/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
+++ b/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
diff --git a/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
b/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
index 00000000..00000000 100644
--- a/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
+++ b/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

3.2 UI Obfuscation(Zero-Day)

```
diff --git a/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
b/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
index 0000000..0000000 100644
```

```
--- a/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
+++ b/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
-         applicationInfo.loadLabel(getPackageManager()));
```

```
+         applicationInfo.loadSafeLabel(getPackageManager()));
```

```
...
```

```
diff --git a/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
b/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
index 0000000..0000000 100644
```

```
--- a/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
+++ b/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
-         applicationInfo.loadLabel(mPackageManager));
```

```
+         applicationInfo.loadSafeLabel(mPackageManager));
```

3.2 UI Obfuscation(Zero-Day)

```
diff --git a/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
b/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
index 0000000..0000000 100644
```

```
--- a/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
+++ b/packages/apps/Settings/src/com/android/settings/security/RequestManageCredentials.java
```

```
@@ -243,11 +243,11 @@ private void loadHeader() {
```

```
...
```

```
-         applicationInfo.loadLabel(getPackageManager()));
```

```
+         applicationInfo.loadSafeLabel(getPackageManager()));
```

```
...
```

```
diff --git a/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
b/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
index 0000000..0000000 100644
```

```
--- a/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
+++ b/packages/apps/Settings/src/com/android/settings/security/CredentialManagementAppAdapter.java
```

```
@@ -84,11 +84,11 @@ public class HeaderViewHolder extends RecyclerView.ViewHolder {
```

```
mAppIconView.setImageDrawable(mPackageManager.getApplicationIcon(applicationInfo));
```

```
-         applicationInfo.loadLabel(mPackageManager));
```

```
+         applicationInfo.loadSafeLabel(mPackageManager));
```

4. LIVE DEMO

Question: Will large language models replace security researchers?

Answer:

- The birth of AFL started a security technology revolution in the fuzzing era, and LLMs are now changing the way we do security research.
- The core value of security researchers has never changed: finding issues, verifying issues, and solving real-world security problems.
- **Tools will keep evolving, but security researchers will not be replaced.**

Key Takeaways

1. N-Day Patches Turn Old Fixes into Reusable Models
2. Large-Codebase Analysis Becomes Scalable Through Task Decomposition
3. LLM Results Become Reliable Through Tool-Based Verification
4. One Concrete Vulnerability Problem Can Scale to Batch Discovery Across Projects
5. LLMs Change Vulnerability Research, but Security Researchers Still Drive It

QA

email: povcfe2sec+blackhat@gmail.com